Today’s topics

Mobile security organizational perspective

- Practitioner’s
- End-user perspective
- Class activities

Practitioner’s perspective

Perspectives of the practitioners

- **Sociological aspects** of the increase in the use of mobile devices as the world transforms rapidly in a move toward mobile ubiquity.
- Challenges surrounding mobile device security for practitioners highlighting the key risks for **individuals**.
- The key mobile security concerns for **organizations** interacting with a **digital native** workforce who rely on these mobile devices.
- **Insights** on various threats, risks, mitigations, mobile security strategies, privacy as well as forensics.
- Implementation of **suggested steps to secure** mobile devices.

Practitioner’s perspective …

Security challenges in today’s businesses

- Mobile devices became user **programmable** and support **third-party** software.
- So, study extends to **security of such third-party software** and associated privacy risks.
- Moreover, the **business** is increasingly likely to be a **mobile enterprise**.
- This is performed using technology, systems, and processes that are designed and built to **support mobility**.
- Work is no longer a place we "go“, **instead it's something we do**.
- However, the proliferation of mobile applications in the workplace is a **serious and expanding threat** to both security and privacy.

Practitioner's perspective …

Strict follow-up to relevant mobile device security principles

- Principles for **end-users and developers** (see previous lectures)
- Principles for **organizations**

Thereby build trust between individuals and organizations: ***apps shall access organizational data responsibly****, secure data storage on mobile device and secure data transmission by ISP.*

Practitioner's perspective …

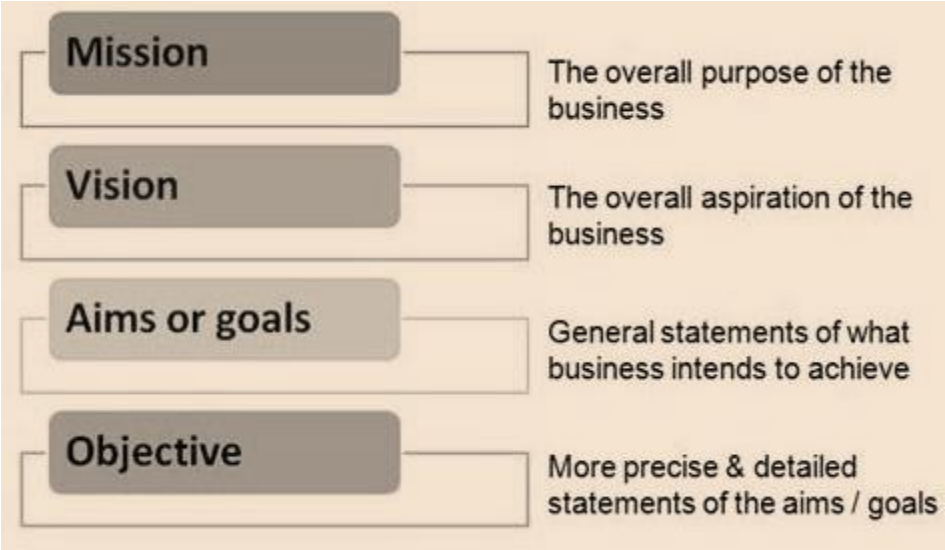
Principles for organizational mobile device security:

- **Embed security** in corporate: governance, risk and compliance strategy.
- Establish **security governance** on the mobile devices. E.g., deliberate decision to impose or not to impose security measures on mobile devices.
- Perform regular **software testing** such as runtime interpretation of code for errors.
- Perform regular **security audits** on mobile apps.
- **Check device defaults** like what services are open, authentication defaults for Wi-Fi or mobile hotspots, etc.

Practitioner's perspective …

Embed security in corporate governance … outcomes

- Strategic **alignment**
- **Risk** management
- Business process **assurance**
- **Value** delivery
- **Resource** management
- **Performance** measurement

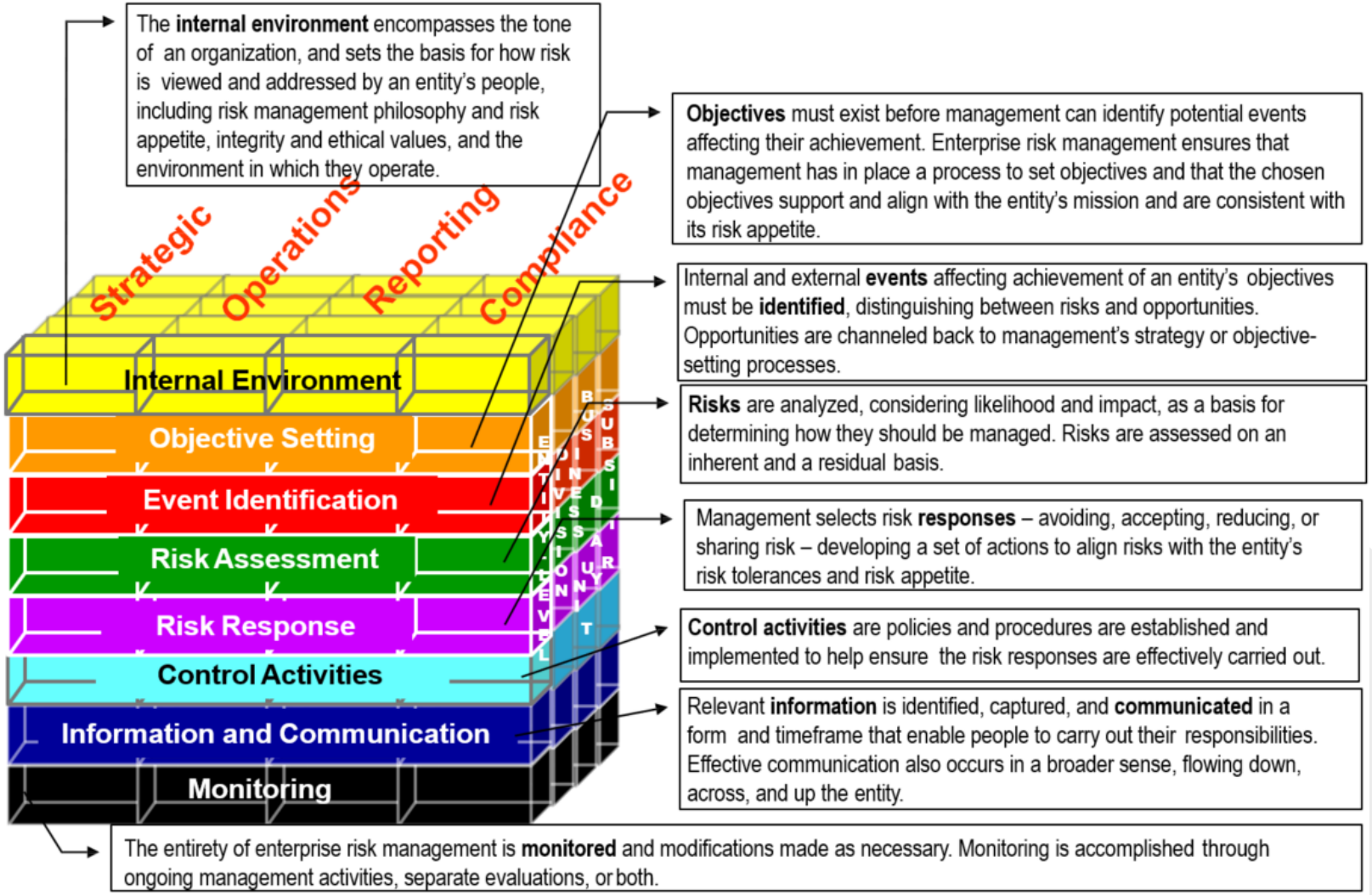


Practitioner's perspective …

Embed security in corporate governance … Apply ERM

- **Enterprise risk management (ERM)** is a set of **methods** and **processes** used by organizations to **manage risks** and **seize opportunities** for achieving **objectives**.
- Enables to align risk **appetite** and strategy and enhance **risk response** decisions.
- **E.g., COSO ERM-** stands for Committee of Sponsoring Organizations of the Treadway Commission (initially to combat fraud in the US).
- COSO ERM is a framework with **eight components** and **four categories** of objectives.
- The COCO principle: "Good risk management and internal control are necessary for **long term success** of all organizations."

Practitioner's perspective …



Practitioner's perspective …

Some of the key risks for **individuals to be aware** of are:

- Information exposure risks of **keeping highly sensitive data** on mobile devices
- Privacy implications of **technological capabilities** that mobile devices provide
- Impact of the mobile device **being lost or stolen** and lack of implementing **encryption**
- **More people having a mobile device** means the 'device is a target that can be exploited.
- The risk of mobile data exposure is **extended by the remote-control capability to spy**.

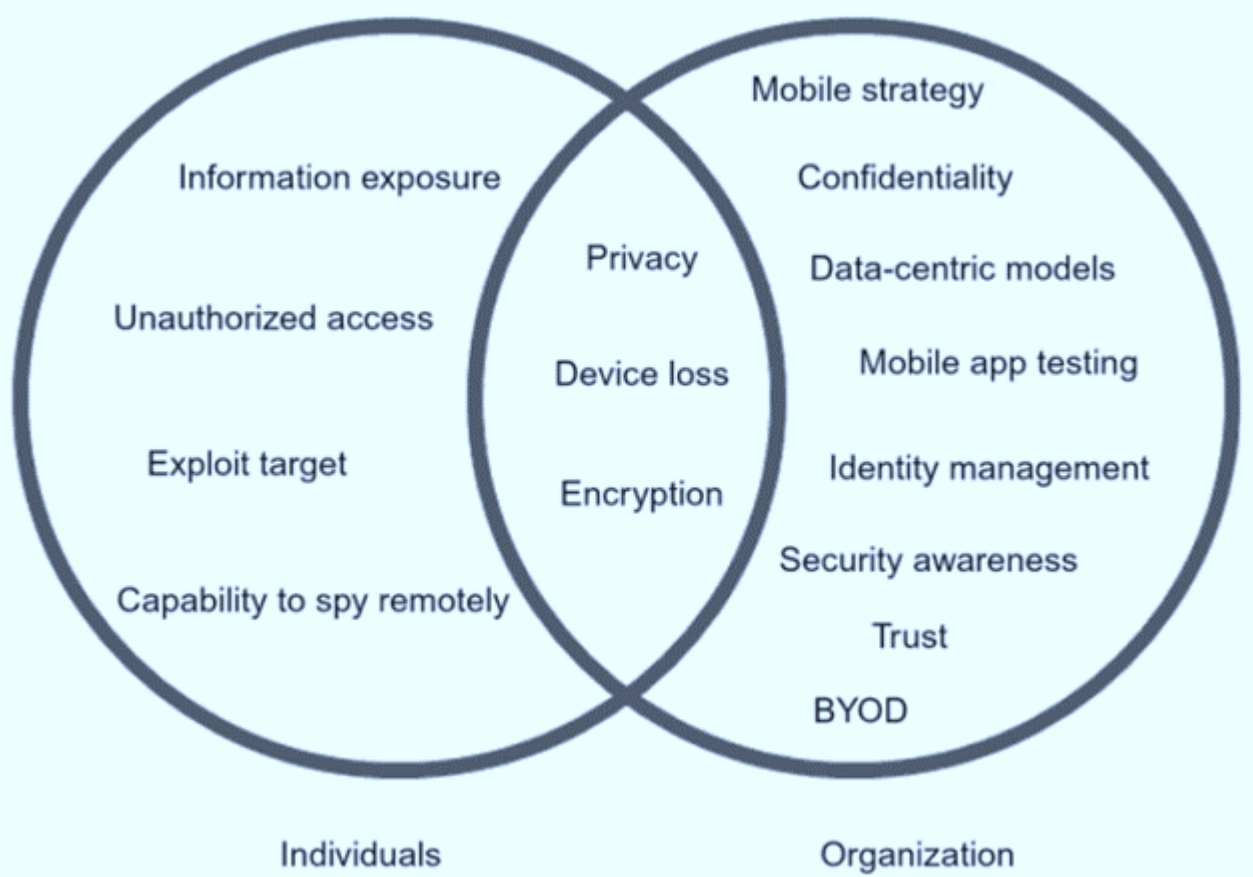
Practitioner’s perspective …

Some of the key **concerns for organizations** are:

- Have suitable **strategies** in place for securing mobile devices.
- Shift the focus to **data-centric** models rather than system or device-centric models.
- **MDM control isn't a universal cure** and products vary with functionality and approach.
- Protection of data through **encryption and test** a mobile app before it goes live.
- **Privacy and identity** management.
- Security awareness training for mobile devices for staff.
- Maintain digital trust with customers.
- Consider **BYOD programs and implications** for organizational policy relating to integration within the organization.

Practitioner's perspective …

The mobile device overlap



End-user perspective

Impact of Internet and mobile adoption

- With the commercialization and widespread usage of the Internet there is a sharp **increase in daily Internet surfing**.
- **Growing adoption rate of mobile** and portable devices witnessed in the developing economies (global South).
- Thus, there is increasing mobile security concern as more and **more activities are migrating** from PC to a mobile platform.

End-user perspective …

Investment on security

- Multinational corporations have **invested on cyber and mobile security**, and they have relatively matured (especially internal network) security.
- However, **small and medium scale firms** usually have fragmented investment in cyber and mobile security due to inherent financial constraints.

End-user perspective …

Impact of end user security awareness

- The security situation for **individual** Internet and mobile end users is even more serious due to proliferation of personalized portable devices.
- Individuals are reluctant to invest in **security software** for their different mobile devices.
- Generally, end users are unaware of the **potential vulnerability** to uninvited third parties who might access those devices.
- This results on the Internet and mobile **end users being the weakest link on the mobile security chain**.

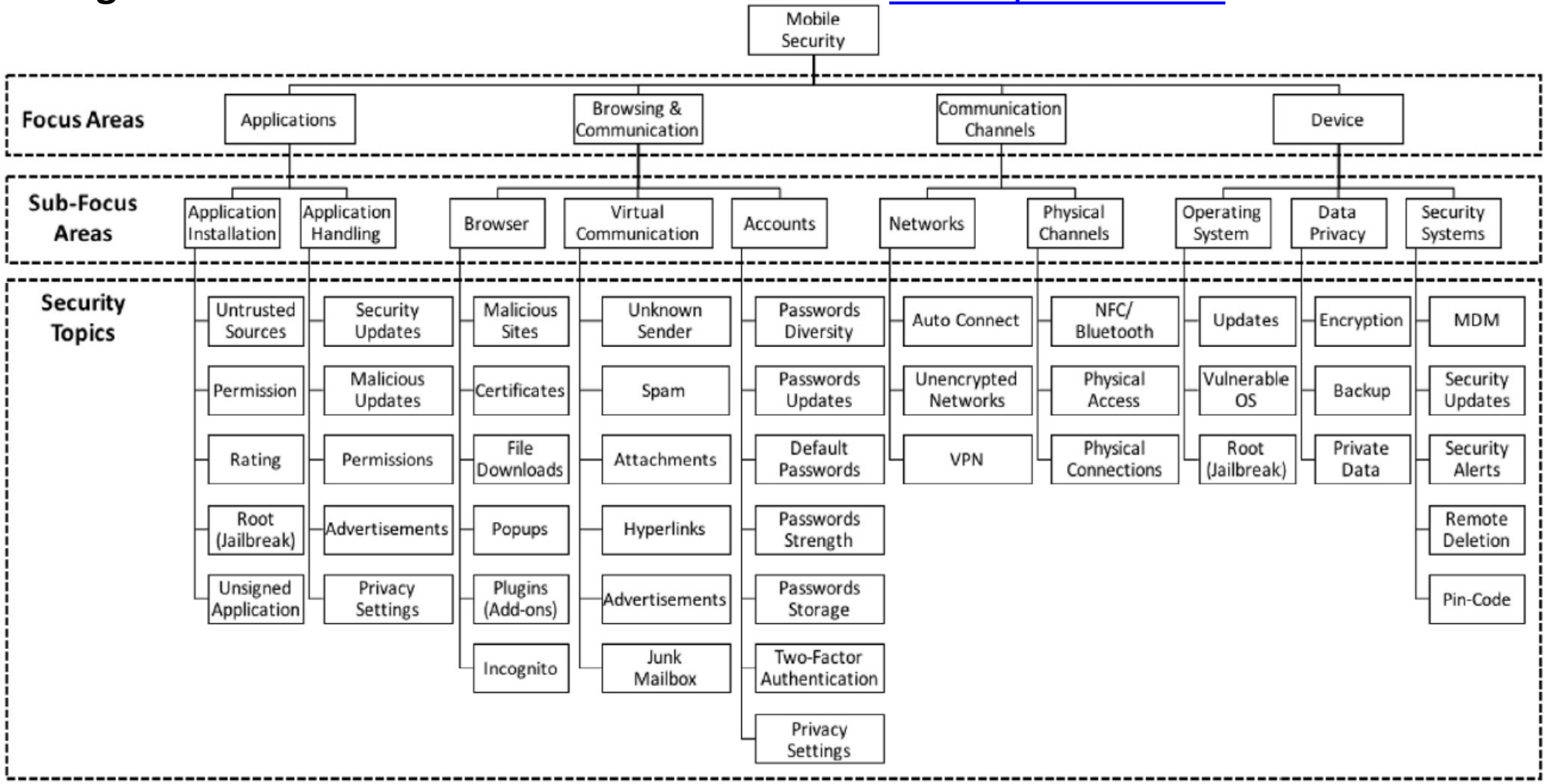
End-user perspective …

In defense of the impact of human factor on security:

- How would we **expect our colleagues to react** if we were to describe them personally like this?
- What are the other **links** in this chain and **how secure are they really**?
- What **breach trajectory** must be created before a human being can become a weak link?
- Has the human-factor been automated out of the system in question?
- Am I **blaming the victim** of a crime?
- Am I **treating end users fairly** and transparently?
- Why are we pushing such a **negative vision of human capability**?
- **Who exactly are we serving** with such a message?

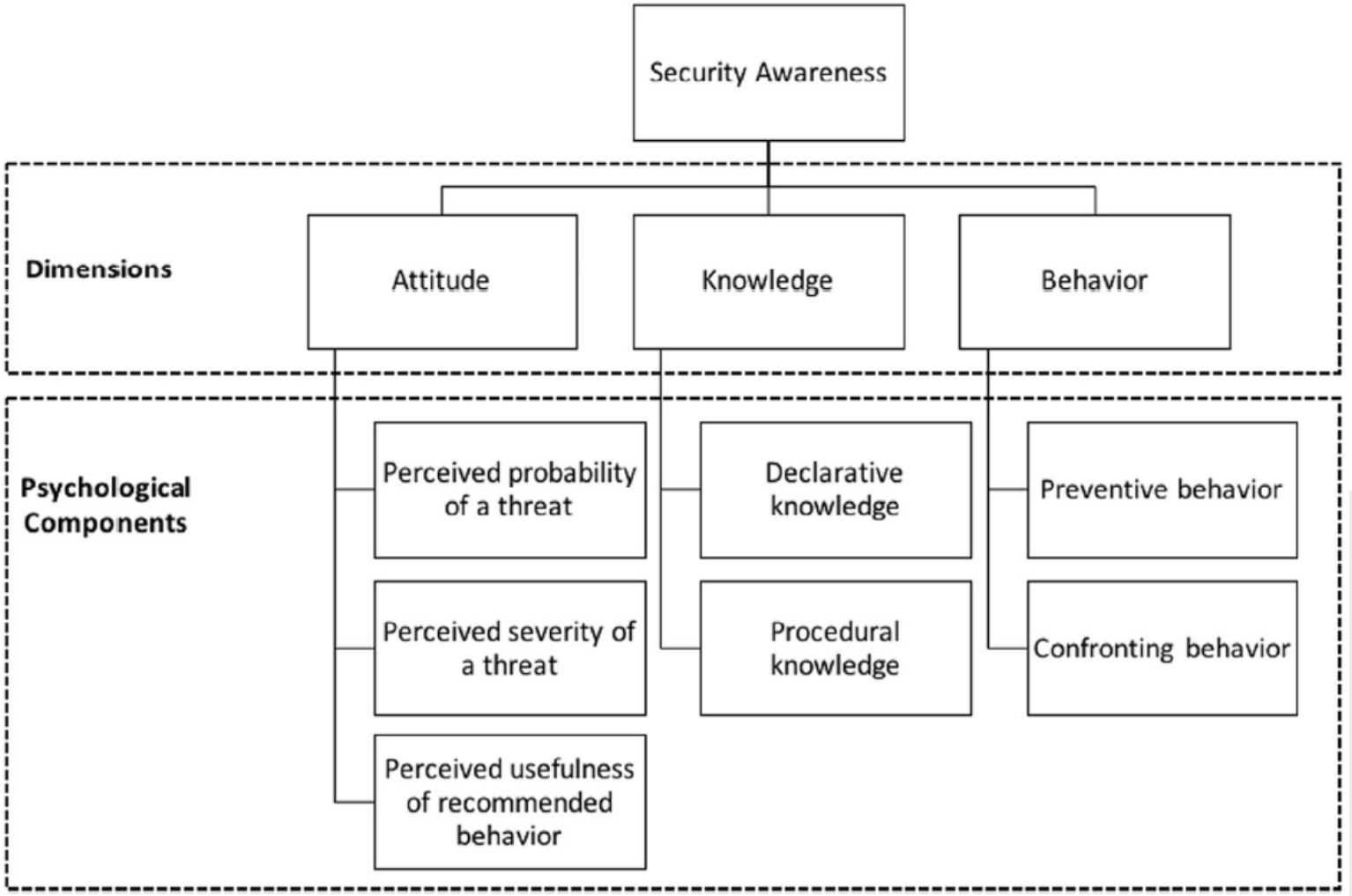
End-user perspective …

Technological elements associated with mobile users' security awareness



End-user perspective …

Taxonomy of mobile users' security **awareness**



Class activities:

1. Individual participation 1:
   Discussion questions via Mentimeter (Week38)
2. Group activity:
   List of tasks to be provided
3. Individual participation 2:
   Questions via Kahoot with from ” Week39”
4. Working on Quiz
   From previous “Week38”
5. Work on “Obligatory assignment 1“

NB: Additional information about the activities yet to be provided in separate document.

Next topics

OWASP mobile security risks, standards, and testing guide